Richtlinie: Cloud Security & Outsourcing

Dokument: SEC-POL-CLOUD-04 | Version: 1.2 | Stand: 2026

ISO 27017	EU / DACH	Jährlich
MINDESTSTANDARD	ZULÄSSIGER SERVERSTANDORT	PROVIDER-AUDIT INTERVALL

§ 1 Grundsätze der Cloud-Nutzung

Das Unternehmen verfolgt eine "Cloud-First"-Strategie für neue IT-Services. Diese Strategie entbindet die Fachbereiche jedoch nicht von ihrer Verantwortung für die Informationssicherheit. Jede Beschaffung und Inbetriebnahme eines neuen Cloud-Dienstes (SaaS, PaaS, IaaS) oder die Auslagerung von IT-Dienstleistungen muss vor Vertragsabschluss durch das CISO-Office und den Datenschutzbeauftragten geprüft und schriftlich freigegeben werden (Vendor Risk Assessment). Es ist strikt untersagt, Unternehmensdaten in nicht genehmigten, privaten oder öffentlichen Cloud-Speichern (sogenannte Schatten-IT, wie private Dropbox-Accounts oder unautorisierte KI-Tools) abzulegen oder zu verarbeiten.

§ 2 Datenklassifizierung und Serverstandort

Die Zulässigkeit eines Cloud-Dienstes richtet sich primär nach der Klassifizierung der Daten, die dort verarbeitet werden sollen. Für Daten der Klassifizierungsstufe "Öffentlich" und "Intern" dürfen globale Cloud-Provider genutzt werden, sofern ein angemessenes Sicherheitsniveau nachgewiesen ist.

Für Daten der Stufe **"Vertraulich"** (z.B. personenbezogene Daten von Kunden und Mitarbeitern, Finanzdaten) gilt die zwingende Anforderung, dass der Cloud-Provider seinen Hauptsitz in der EU hat und die physischen Rechenzentren zur Datenverarbeitung und Datenspeicherung ausschließlich innerhalb der Europäischen Union (präferiert im DACH-Raum) betrieben werden. Daten der Stufe **"Streng Vertraulich"** (z.B. Quellcode, strategische M&A-Pläne, kryptografische Schlüsselmaterialien) dürfen grundsätzlich nicht in Public-Cloud-Umgebungen verarbeitet werden, sondern müssen zwingend auf On-Premise-Systemen des Unternehmens verbleiben.

§ 3 Kryptografische Vorgaben (Verschlüsselung)

Alle Daten, die an einen Cloud-Dienstleister übertragen werden, müssen sowohl bei der Übertragung (Data in Transit) als auch bei der Speicherung (Data at Rest) nach dem aktuellen Stand der Technik stark verschlüsselt werden. Für die Verschlüsselung bei der Übertragung ist zwingend TLS in der Version 1.3 (oder mindestens Version 1.2 mit Perfect Forward Secrecy) vorzuschreiben. Bei IaaS- und PaaS-Infrastrukturen muss das Prinzip "Bring Your Own Key" (BYOK) angewendet werden, sofern technisch möglich. Das bedeutet, dass das Schlüsselmaterial im unternehmenseigenen Key Management System (KMS) verbleibt und der Cloud-Provider zu keinem Zeitpunkt administrativen Zugriff auf die unverschlüsselten Rohdaten erhält.

§ 4 Exit-Strategie und Vendor Lock-In

Vor Abschluss eines Cloud-Vertrags muss für kritische Dienstleistungen eine dokumentierte Exit-Strategie vorliegen. Diese Strategie muss detailliert beschreiben, wie die Unternehmensdaten bei einer Vertragskündigung oder Insolvenz des Anbieters in einem standardisierten, maschinenlesbaren Format (z.B. JSON, CSV, SQL-Dump) exportiert werden können. Der Vertrag muss garantieren, dass der Provider nach erfolgreicher Migration alle unsere Daten auf seinen Systemen unwiderruflich löscht und dies mit einem Löschprotokoll zertifiziert.

> **Anforderung aus dem DORA-Rahmenwerk:** Für IT-Dienstleister, die kritische oder wichtige Funktionen (ICT) unterstützen, müssen Verträge klare Kündigungsrechte, Zugangs- und Inspektionsrechte (Audit-Rechte vor Ort) sowie die Pflicht zur Mitwirkung bei Penetrationstests enthalten. Verträge ohne ein solches Audit-Recht dürfen nicht unterzeichnet werden.